SUPPORT ÉTUDIANT

DSP2 et Open Banking

Jour 2 : API, authentification et sécurité

Chrisvene MPANDZOU

chrisvene.mpandzou@a2mtech.com

M2 SIB · 2026 – 2027

Sommaire

Repères de lecture du polycopié

01 Introduction & objectifs 3

02 S1 · Architecture API 4

03 S2 · Workflow AIS 7

04 S3 · Workflow CBPII 10

05 S5 · Authentification & autorisation 12

06 S6 · Sécurité & conformité 15

07 S7 · Cas pratique 18

Introduction & objectifs

ACCUEIL

Intro & objectifs

Le Jour 1 a posé le pourquoi et le qui. Le Jour 2 passe au comment technique : de quoi est faite une API bancaire, par quels mécanismes un tiers est autorisé, et comment l'ensemble reste sûr et conforme.

FIL ROUGE

Samedi, 9 h 12. L'application de Lyam prépare sa requête. Elle doit **prouver qui elle est** (le TPP), obtenir une **autorisation** (le consentement de Lyam), puis présenter un **jeton** à chaque appel. Le Jour 2 ouvre ce capot.

RAPPEL

Ce que l'on a fixé au Jour 1

DSP2 = **Deuxième Directive sur les Services de Paiement** (directive (UE) 2015/2366). **Open Banking** = l'ouverture des données de compte et des paiements à des tiers agréés, avec le consentement du client. La DSP2 est la règle, l'Open Banking la pratique, et l'**API** en est l'outil technique — celui que l'on étudie aujourd'hui.

Le fil conducteur du Jour 2

Une API Open Banking protège trois choses en même temps : l'**identité du tiers**, l'**autorisation du client** et l'**intégrité de chaque appel**. Chaque bloc du jour correspond à l'une de ces protections.

APERÇU

Le parcours du Jour 2, en une image

Quatre séquences, du composant au cas concret. On part de la brique API, on monte jusqu'aux mécanismes d'authentification, puis aux exigences de sécurité, pour finir par une mise en situation complète.

S1 — Architecture API

Les types d'API (AIS, PIS, CBPII) et les composants qui les exposent : Gateway, API Management, throttling, logs.

S2 — Authentification & autorisation

OAuth2, OpenID Connect, mTLS, JWT : qui prouve son identité, et comment l'accès aux données est-il borné ?

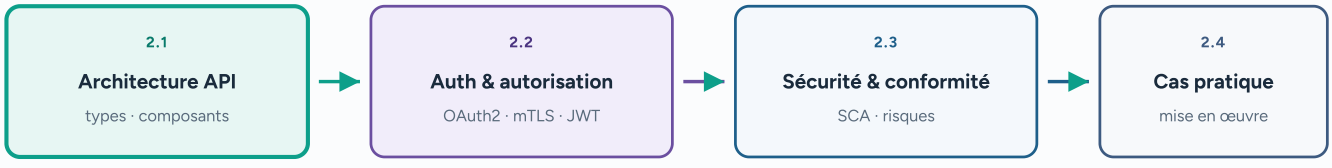
S3 — Sécurité & conformité

Exigences DSP2 : SCA, exemptions, non-répudiation, horodatage. Et les risques : usurpation, attaques API, fuites.

S4 — Cas pratique

Ouvrir une API à un TPP de bout en bout : schéma d'architecture, flux OAuth, points de contrôle de sécurité.

Fil du Jour 2



OBJECTIFS PÉDAGOGIQUES

À l'issue du Jour 2, l'étudiant sait…

- **Distinguer** les trois types d'API Open Banking — Account Information (AIS), Payment Initiation (PIS), Confirmation of Funds (CBPII) — et leurs composants (Gateway, API Management, throttling).
- **Expliquer** les mécanismes d'authentification et d'autorisation : OAuth2, OpenID Connect, mTLS, JWT, et la séparation entre identité du client, identité du TPP et autorisation d'accès.
- **Relier** les exigences DSP2 de sécurité (SCA, exemptions, non-répudiation, horodatage) aux mécanismes techniques qui les mettent en œuvre.
- **Identifier** les risques propres aux API (usurpation d'identité, attaques API, fuites de données) et les contre-mesures associées.
- **Concevoir** l'ouverture sécurisée d'une API bancaire à un TPP : schéma d'architecture, flux OAuth et points de contrôle de sécurité.

ORGANISATION

Déroulé des 4 heures

TEMPS	BLOC	MODALITÉ	LIVRABLE
0 h 00 – 0 h 10	Intro & objectifs	Plénière	Vision d'ensemble
0 h 10 – 1 h 00	2.1 Architecture API	Exposé + schéma	Carte des types d'API
1 h 00 – 1 h 55	2.2 Authentification & autorisation	Exposé + démonstration	Flux OAuth annoté
1 h 55 – 2 h 05	Pause	—	—
2 h 05 – 2 h 55	2.3 Sécurité & conformité	Exposé + discussion	Tableau exigences / risques
2 h 55 – 4 h 00	**2.4 Cas pratique**	**Travaux de groupe**	**Schéma + flux + contrôles**

Ce qu'il faut avoir retenu du Jour 1

Les rôles ASPSP / TPP, la chaîne Gateway → consentement → IAM → core banking, et le parcours de redirection. Ces acquis sont réutilisés en permanence : on ne les redéfinit plus, on les approfondit.

02 · S1 · ARCHITECTURE API

S1 - Architecture API

UNE INFRASTRUCTURE, TROIS SERVICES

Architecture API — le socle commun

AIS, PIS, CBPII : trois API aux usages différents, mais bâties sur **la même infrastructure d'exposition**. On commence par ce socle commun — passerelle, gestion, services, journalisation — avant de détailler chaque API dans les

séquences suivantes.

FIL ROUGE L'application de Lyam n'utilise pas « une API » : elle appelle une API de **lecture de comptes** (AIS). Demain, si Lyam paie un marchand par virement, ce sera une API d'**initiation de paiement** (PIS). Derrière ces appels différents, la banque expose toujours la *même* plomberie : c'est ce socle qu'on découvre ici.

ORIENTATION

Trois API, un même socle

La DSP2 définit trois familles de services, chacune exposée par une API dédiée. Leur *logique métier* diffère ; leur *infrastructure d'exposition* est commune. Cette séquence pose le socle ; les deux suivantes détaillent le workflow propre à l'AIS et au CBPII. Le PIS, lui, fait l'objet du Jour 3.

Account Information API

LECTURE DES COMPTES · AIS

Lit soldes, opérations et détails de comptes. **Lecture seule**, aucun mouvement de fonds.

→ S2 · détail de l'API AIS

Payment Initiation API

INITIATION DE PAIEMENT · PIS

Déclenche un virement au nom du client, sans jamais détenir les fonds.

→ détaillé au Jour 3

Confirmation of Funds API

VÉRIFICATION DE FONDS · CBPII

Répond « fonds disponibles ? » sans exposer de solde.

→ S3 · workflow CBPII

Une API, un usage

Une banque peut exposer les trois types, mais un TPP n'accède qu'aux types couverts par son agrément. Un AISP n'obtient jamais le droit d'appeler l'API de paiement : la séparation est technique *et* réglementaire.

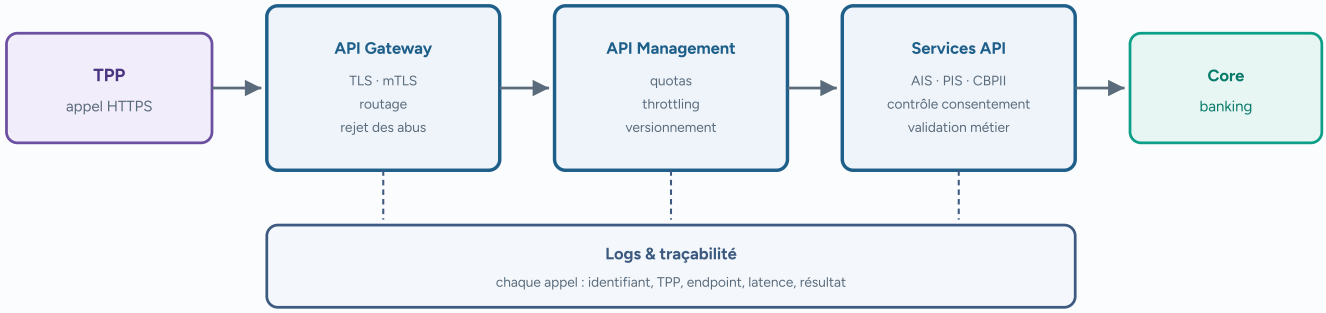
COMPOSANTS

Les composants qui exposent l'API

Quelle que soit l'API appelée, l'appel traverse la même chaîne de composants. On retrouve ici les couches du

Jour 1, vues cette fois du côté de l'exposition.

De l'appel TPP au service métier



1 API Gateway

Point d'entrée unique. Termine le chiffrement, vérifie le certificat du TPP (mTLS), route vers le bon service et rejette les appels malformés ou abusifs.

2 API Management

Gère le catalogue d'API, les quotas par TPP, le *throttling* (limitation de débit) et le versionnement. C'est l'endroit où l'on décide qui a le droit d'appeler quoi, à quelle fréquence.

3 Services API métier

Implémentent réellement AIS, PIS, CBPII : vérification du consentement, contrôle du périmètre, validation des règles métier avant d'appeler le core banking. C'est ici que chaque API devient *différente* (S2 AIS, S3 CBPII).

4 Logs & traçabilité

Chaque appel est journalisé : qui (TPP), quoi (endpoint), quand (horodatage), résultat (code), et combien de temps. Indispensable à l'audit, aux litiges et au monitoring.

Throttling : pourquoi c'est une exigence, pas une option

Les RTS imposent des plafonds de consultation. Sans limitation de débit, un TPP mal codé peut saturer l'API et faire tomber, pour tous les autres, l'accès aux comptes. Le throttling protège la disponibilité du service — donc la qualité pour Lyam.

SÉQUENCE SUIVANTE

Maintenant, chaque API en détail

Le socle est posé. On peut désormais spécialiser : chaque API a son cœur métier, ses endpoints, ses règles SCA et ses risques propres. Commençons par la plus utilisée : la lecture de comptes (S2 · AIS).

COURS — RÉCAPITULATIF DU BLOC

- **Trois API, un socle** : AIS (lecture), PIS (paiement), CBPII (fonds) partagent la même infrastructure d'exposition.
- **Composants** : Gateway (entrée), API Management (quotas, throttling, versionnement), Services métier, Logs.
- **Point de divergence** : c'est dans les *services métier* que chaque API devient spécifique (workflow AIS en S2, CBPII en S3 ; PIS au Jour 3).
- **Principe** : un seul type par agrément, séparation technique et réglementaire.

03 · S2 · WORKFLOW AIS

S2 - Workflow AIS

LIRE LES COMPTES, JAMAIS LES TOUCHER

Workflow AIS — Account Information

L'API que Lyam utilise au quotidien : lire ses soldes et ses opérations depuis son application. Sur le socle de S1, elle ajoute un cœur métier précis : **lecture seule**, cadrée par un consentement et une authentification forte initiale.

FIL ROUGE

Lyam ouvre son application de gestion de budget. Elle affiche la liste de ses comptes, le solde de chacun et ses dernières opérations. Pour cela, elle appelle l'API AIS de Banque Est avec le consentement que Lyam a donné une fois — et qui reste valable jusqu'à 90 jours.

CŒUR MÉTIER

Ce que fait — et ne fait pas — l'API AIS

Ce qu'elle fait

- Lister les comptes (comptes courants, livrets, cartes)
- Donner le détail d'un compte (IBAN, titulaire, type)
- Lister les transactions d'un compte, filtrables par date
- Donner les soldes (comptabilisé, disponible)

Ce qu'elle ne fait jamais

- Aucun mouvement de fonds (pas de virement, pas de prélèvement)
- Aucune modification du compte
- Aucun accès sans consentement AIS actif
- Aucun accès aux comptes non couverts par le consentement

LE PRINCIPE

L'AISP lit ; il ne touche à rien. Le risque de l'AIS n'est pas la fraude financière, c'est la confidentialité des données de comptes.

PARCOURS

Le parcours d'une lecture de comptes

Une lecture AIS suit toujours la même séquence : consentement, authentification forte initiale, puis lecture

répétée tant que le consentement est valide.

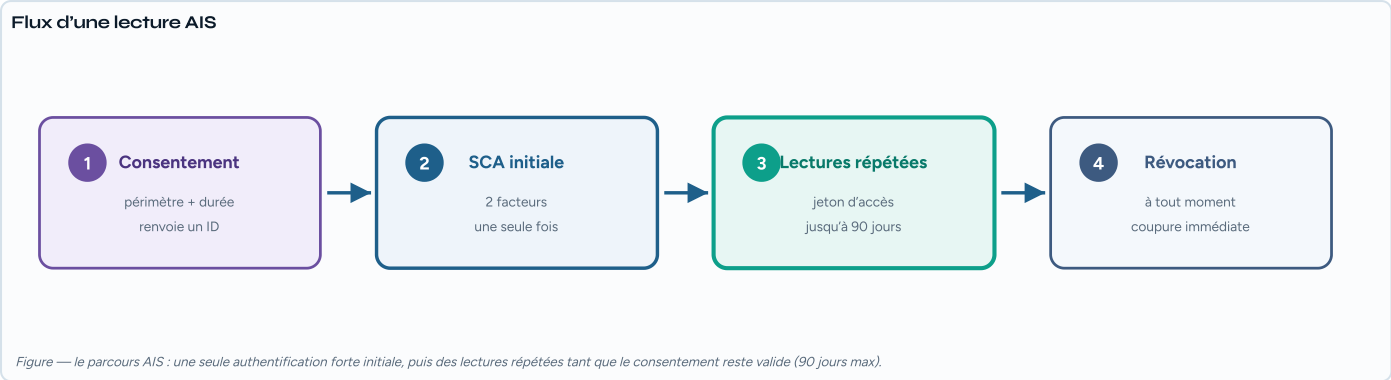


Figure — le parcours AIS : une seule authentification forte initiale, puis des lectures répétées tant que le consentement reste valide (90 jours max).

1 **Création du consentement**

L'AISP déclare au nom de Lyam ce qu'il veut lire (comptes, transactions, soldes) et pour combien de temps. La banque renvoie un identifiant de consentement.

2 **SCA initiale**

Lyam s'authentifie fortement (deux facteurs) auprès de sa banque et autorise explicitement le consentement. C'est le seul moment où il prouve son identité.

3 **Lecture répétée**

Avec un jeton d'accès, l'AISP lit les comptes et les transactions. Plus de SCA à chaque lecture : l'accès reste ouvert jusqu'à expiration du consentement (
max 90 jours
sous RTS).

4 **Révocation**

Lyam peut révoquer le consentement à tout moment. L'accès est coupé immédiatement, quelles que soient les jetons en circulation.

ÉTAPE	ENDPOINT TYPIQUE (BERLIN GROUP)	BUT
Consentement	`POST /v1/consents`	Déclarer le périmètre et la durée
Comptes	`GET /v1/accounts`	Lister les comptes autorisés
Détail	`GET /v1/accounts/{accountId}`	IBAN, titulaire, type
Soldes	`GET /v1/accounts/{accountId}/balances`	Solde comptabilisé / disponible
Transactions	**`GET /v1/accounts/{accountId}/transactions`**	**Opérations, filtrables par date**

Les noms exacts varient selon le standard (Berlin Group, STET, OBIE). Ce qui est normalisé par la DSP2, c'est le service rendu, pas l'URL.

DONNÉES

À quoi ressemble une réponse AIS

L'AIS renvoie des données riches — c'est justement ce qui le rend sensible. Exemple simplifié d'une réponse

« transactions » :

```
{
  "account": { "iban": "FR76…1234" },
  "transactions": {
    "booked": [
      {
        "transactionId": "TX-2025-0001",
        "bookingDate": "2025-11-08",
        "amount": { "currency": "EUR", "amount": "-42.90" },
        "creditorName": "SNCF",
        "remittanceInformation": "Billet Paris–Lyon"
      },
      {
        "transactionId": "TX-2025-0002",
        "bookingDate": "2025-11-07",
        "amount": { "currency": "EUR", "amount": "2500.00" },
        "debtorName": "ACME SARL",
        "remittanceInformation": "Salaire novembre"
      }
    ]
  }
}
```

Pourquoi c'est sensible

Une réponse AIS révèle les revenus, les habitudes d'achat, les bénéficiaires, la santé financière de Lyam. C'est une donnée personnelle au sens du RGPD : d'où le consentement explicite, la durée bornée et le droit de révocation à tout moment.

RISQUES

Les erreurs et risques propres à l'AIS

CODE HTTP	SIGNIFICATION	CE QUE FAIT L'AISP
401	Jeton absent ou invalide	Re-authentifier, redemander la SCA si besoin
403	Consentement expiré ou révoqué	Demander un nouveau consentement à Lyam
429	Trop de requêtes (throttling)	Ralentir, respecter les plafonds RTS
503	**Service indisponible**	**Réessayer avec backoff, prévenir l'utilisateur**

Le piège : le stockage des données

L'AISP ne doit conserver les données lues que pour la durée strictement nécessaire au service rendu. Un AISP qui garde une copie intégrale des transactions « au cas où » sort de son cadre — et s'expose au RGPD comme à la DSP2.

SÉQUENCE SUIVANTE

Et si l'on ne faisait que vérifier ?

L'AIS lit beaucoup. La troisième API, elle, répond à une seule question — « y a-t-il assez de fonds ? » — sans révéler de solde. C'est un tout autre workflow, minimaliste par choix (S3 · CBPII).

COURS — RÉCAPITULATIF DU BLOC

- **Rôle** : lecture seule des comptes, soldes et transactions.
- **Parcours** : consentement → SCA initiale → lecture répétée → révocation.
- **Durée** : consentement valable jusqu'à 90 jours (RTS), une seule SCA initiale.
- **Risque** : confidentialité des données (revenus, habitudes), conformité RGPD.

04 · S3 · WORKFLOW CBPII

S3 · Workflow CBPII

UNE SEULE QUESTION, UNE SEULE RÉPONSE

Workflow CBPII — Confirmation of Funds

La plus discrète des trois API : elle répond à une unique question — « y a-t-il assez de fonds pour ce montant ? » — par un simple **oui ou non**, sans jamais révéler de solde ni d'opération.

FIL ROUGE

Lyam a une carte de paiement adossée à un porte-monnaie géré par un émetteur. Avant d'autoriser une dépense, l'émetteur demande à Banque Est : « le compte de Lyam couvre-t-il 42,90 € ? ». Réponse : oui ou non. L'émetteur n'apprend ni le solde, ni les opérations de Lyam.

CŒUR MÉTIER

Une API volontairement pauvre

Là où l'AIS expose des données riches, le CBPII expose le minimum nécessaire. C'est un choix de conception protecteur : moins de données exposées, moins de risque.

Ce qu'elle fait

- Répond oui/non à « fonds suffisants pour tel montant ? »
- Se limite au compte et au montant demandés
- Sert de contrôle avant une autorisation de paiement

Ce qu'elle ne fait jamais

- Renvoyer un solde (même approximatif)
- Lister des transactions
- Déplacer des fonds
- Donner des informations sur d'autres comptes

LE PRINCIPE

Le CBPII ne lit pas : il *vérifie*. Une réponse binaire vaut mieux qu'un solde exposé — c'est la protection par la pauvreté de la donnée.

PARCOURS

Le parcours d'une vérification de fonds

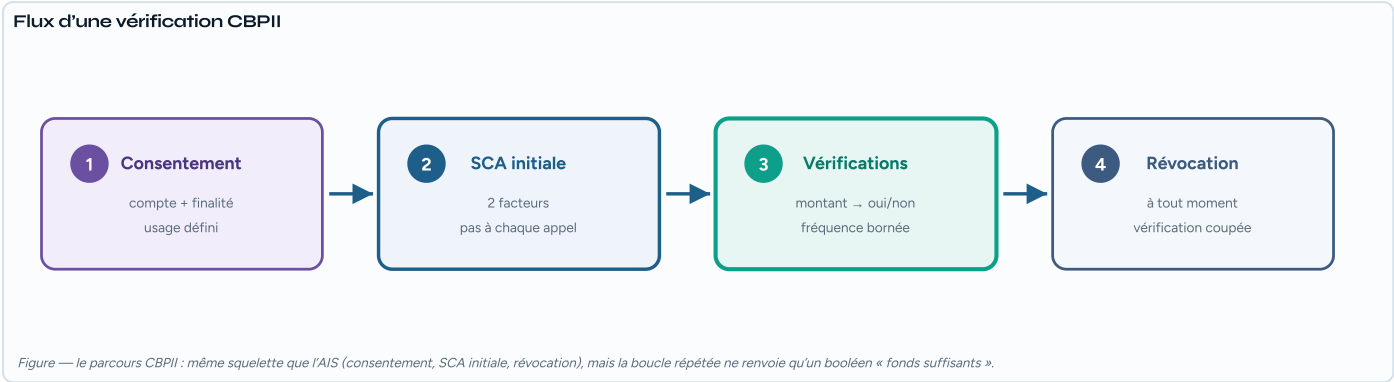


Figure — le parcours CBPII : même squelette que l'AIS (consentement, SCA initiale, révocation), mais la boucle répétée ne renvoie qu'un booléen « fonds suffisants ».

1 **Consentement CBPII**

Le CBPII obtient le droit de vérifier les fonds d'un compte donné pour un usage défini. Le consentement précise le compte et la finalité.

2 **SCA initiale**

Comme pour l'AIS, une authentification forte initiale est requise pour établir le consentement. Le CBPII ne s'authentifie pas à chaque vérification.

3 **Vérification répétée**

Pour chaque dépense, le CBPII envoie le montant et reçoit un booléen. La fréquence est bornée par les RTS (pas d'interrogation abusive du solde par ce biais).

4 **Révocation**

Lyam peut retirer le consentement ; le CBPII perd alors toute possibilité de vérifier les fonds.

ÉTAPE	ENDPOINT TYPIQUE (BERLIN GROUP)	BUT
Consentement	`POST /v1/funds-confirmations`	Déclarer le compte à vérifier
Vérification	appel avec montant + compte	Obtenir « fonds suffisants : oui/non »

DONNÉES

À quoi ressemble une réponse CBPII

La réponse est minimale. Pas de montant de solde, pas de transaction : un seul indicateur booléen.

```
{
  "fundsAvailable": true,
  "account": { "iban": "FR76…1234" }
}
```

Un booléen, pas un solde

Pourquoi ne pas simplement renvoyer le solde ? Parce que le solde est une donnée sensible. Le CBPII n'a besoin que de la réponse à sa question : le minimum exposé est le maximum protégé.

USAGES

Cas d'usage et limites

CAS D'USAGE	INTÉRÊT DU CBPII
Porte-monnaie / carte prépayée	Vérifier la couverture avant d'autoriser
Émetteur de carte	Contrôle de solvabilité sans voir les comptes
Paiement en plusieurs fois	**S'assurer de la capacité de remboursement**

Le piège : l'interrogation abusive

Multiplier les vérifications permet de reconstituer un solde par déduction. Les RTS limitent donc la fréquence d'interrogation — c'est le même enjeu de *throttling* vu en S1, mais ici pour protéger une donnée déduite, pas un service.

COURS — RÉCAPITULATIF DU BLOC

- **Rôle** : répondre oui/non à « fonds suffisants pour ce montant ? ».
- **Minimalisme** : jamais de solde, jamais de transactions.
- **Parcours** : consentement → SCA initiale → vérifications répétées → révocation.
- **Risque** : reconstitution du solde par interrogation répétée (bornée par les RTS).

05 · S5 · AUTHENTIFICATION & AUTORISATION

S5 · Authentification & autorisation

QUI PROUVE QUOI, ET JUSQU'OÙ

Authentification & autorisation

Quatre mécanismes reviennent sans cesse en Open Banking : OAuth2, OpenID Connect, mTLS et JWT. Chacun répond à une question différente. Les confondre, c'est ouvrir une faille.

FIL ROUGE

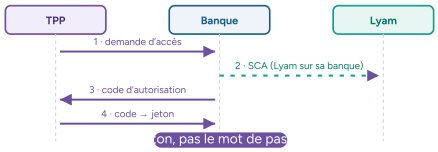
Quand l'application de Lyam appelle Banque Est, trois choses doivent être vraies : **l'appel vient d'un TPP agréé**, **Lyam s'est authentifiée**, et **l'accès demandé est bien couvert par son consentement**. Un seul mécanisme ne suffit pas.

Les quatre mécanismes clés

OAuth2

AUTHORIZATION FRAMEWORK

Cadre d'**autorisation**. Il permet à un TPP d'obtenir un **jeton d'accès** sans jamais connaître les identifiants de Lyam.



Le TPP échange un code contre un jeton : il n'a jamais les identifiants de Lyam.

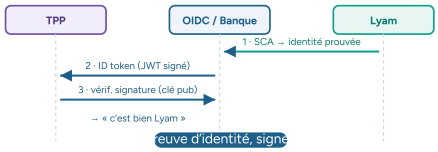
COURS — À RETENIR

OAuth2 n'authentifie pas : il *autorise*. Flux clé en Open Banking : le **code d'autorisation** avec redirection. Le TPP reçoit un code, l'échange contre un jeton.

OpenID Connect

COUCHE D'IDENTITÉ SUR OAUTH2

Ajoute l'**identité** à OAuth2 : un **ID token** (JWT) qui atteste qui est l'utilisateur authentifié.



OIDC ajoute à OAuth2 un ID token : le TPP sait *qui* est l'utilisateur, pas seulement ce à quoi il a droit.

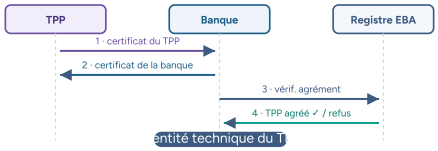
COURS — À RETENIR

OIDC répond à « qui est cet utilisateur ? », là où OAuth2 répond à « à quoi a-t-il droit ? ». En Open Banking, l'ID token prouve l'identité de Lyam côté TPP.

mTLS

MUTUAL TLS

Authentification mutuelle par certificat. Le TPP et la banque se présentent chacun un certificat : chacun prouve son identité à l'autre.



Le canal est établi seulement si les deux certificats sont valides : mTLS prouve que le TPP est le TPP agréé.

COURS — À RETENIR

mTLS est la preuve que **le TPP est bien le TPP agréé**, au niveau du canal. Le certificat est lié à l'agrément (registre EBA) : c'est un contrôle d'identité technique.

JWT

JSON WEB TOKEN

Format de jeton **signé**. Il transporte des affirmations (scopes, expiration, émetteur) vérifiables sans rappeler le serveur à chaque fois.



JWT = `header.payload.signature`. Le contenu est *lisible* par tous : la signature garantit seulement qu'il n'a pas été modifié.

COURS — À RETENIR

Un JWT est *signé*, pas *chiffré* : on peut le lire. Il ne doit donc jamais contenir de données sensibles. Sa signature garantit qu'il n'a pas été modifié.

MÉCANISME	RÉPOND À LA QUESTION	NIVEAU
mTLS	Le TPP est-il bien celui qu'il prétend ?	Canal
OAuth2	À quoi le TPP a-t-il droit ?	Autorisation
OpenID Connect	Qui est l'utilisateur authentifié ?	Identité
JWT	**Comment transporter la preuve, signée ?**	**Jeton**

LE POINT CLÉ

Trois authentifications, trois autorisations

Il faut bien séparer trois notions distinctes, que l'on ne doit jamais fusionner.

Identification du client

Lyam prouve qui il est auprès de sa banque (SCA). C'est lui, physiquement et juridiquement, qui est à l'origine de la demande.

Identification du TPP

L'application prouve qu'elle est un TPP agréé (certificat, agrément). C'est une identité technique, liée au registre EBA.

Autorisation d'accès

Le périmètre concédé à ce client et à ce TPP : quels comptes, quelles opérations, jusqu'à quand. C'est le consentement, matérialisé en jetons.

Ne jamais faire l'impasse sur une des trois

Un TPP valide qui accède au compte d'un client qui n'a pas consenti = faille. Un client authentifié dont le TPP n'est pas agréé = faille. Un consentement large exploité par un TPP malveillant = faille. Les trois contrôles sont indépendants et tous nécessaires.

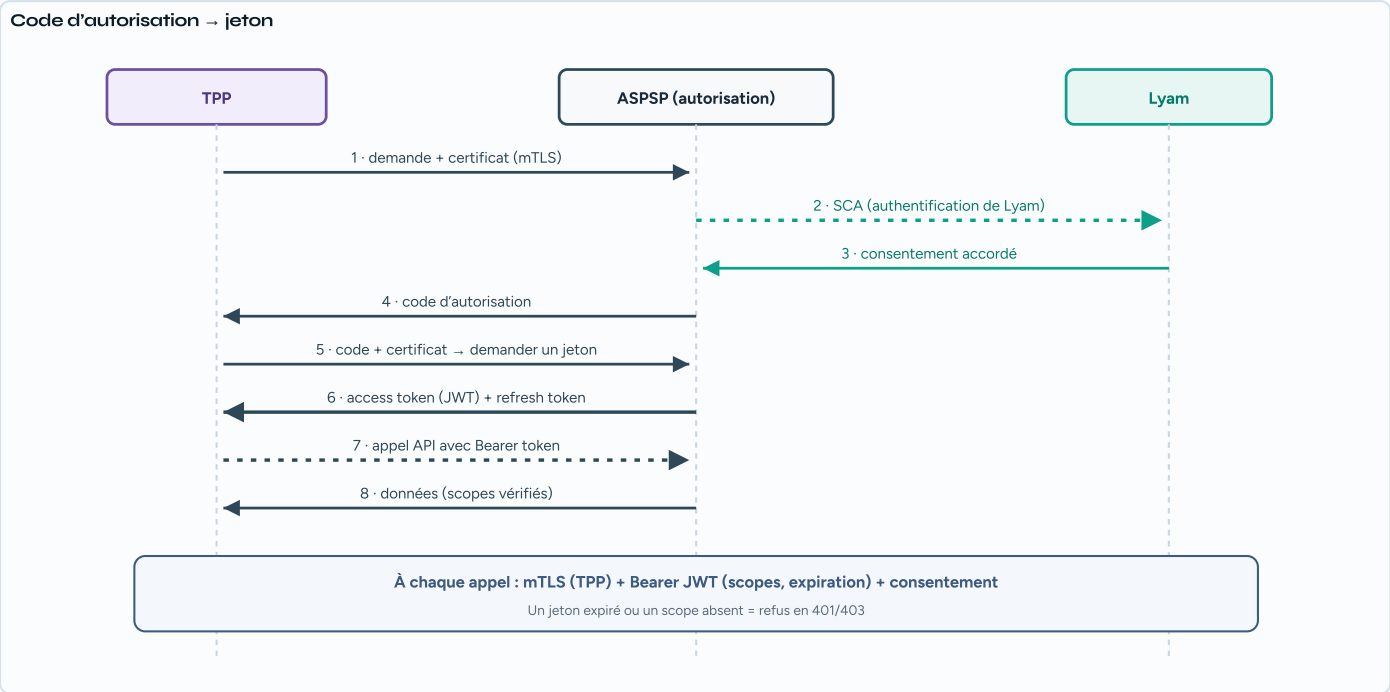
RÈGLE À RETENIR

Authentifier le client ≠ authentifier le TPP ≠ autoriser l'accès aux données. Ces trois vérifications se font à des endroits différents de la chaîne, avec des mécanismes différents.

FLUX

Le flux OAuth2 en Open Banking

Le parcours de redirection du Jour 1, vu cette fois avec les jetons et les contrôles.



Deux jetons, deux rôles

L'**access token** est court (quelques minutes à quelques heures) et porte les scopes. Le **refresh token** sert à en obtenir un nouveau sans redemander la SCA — dans les limites du consentement et des règles d'authentification. Ne jamais confondre leur durée de vie.

SÉQUENCE SUIVANTE

Et les obligations réglementaires ?

Les mécanismes techniques sont posés. Mais la DSP2 impose des exigences précises : SCA, exemptions, non-répudiation, horodatage. Et l'industrialisation de ces flux expose à des risques : usurpation, attaques API, fuites. C'est la S6.

06 · S6 · SÉCURITÉ & CONFORMITÉ

S6 - Sécurité & conformité

EXIGENCES DSP2 ET RISQUES API

Sécurité & conformité

La DSP2 ne dit pas seulement « protégez » : elle impose des mécanismes précis (SCA, exemptions, non-répudiation, horodatage) et laisse aux banques la responsabilité de tenir leurs APIs contre des menaces concrètes.

FIL ROUGE Lyam s'est authentifiée et l'application a son jeton. Mais que se passe-t-il si quelqu'un usurpe le TPP ? Si un appel est rejoué ? Si des données fuitent ? Cette séquence répond à ces menaces.

SCA

La Strong Customer Authentication

> La **SCA** (authentification forte du client) exige au moins **deux facteurs indépendants** parmi trois catégories : **connaissance** (mot de passe, code), **possession** (téléphone, token), **inhérence** (empreinte, visage). Les deux facteurs doivent être de catégories différentes et leur compromission isolée ne doit pas suffire à contourner l'authentification.

Connaissance

Quelque chose que Lyam **sait** : mot de passe, code PIN.

Possession

Quelque chose que Lyam **possède** : son téléphone, une carte.

Inhérence

Quelque chose que Lyam **est** : empreinte digitale, reconnaissance faciale.

Quand la SCA s'applique

À l'accès initial aux comptes (AIS), puis lors des re-authentifications périodiques (au moins tous les 90 jours en AIS), et **à chaque paiement** initié par un PISP, sauf exemption applicable. Deux mots de passe ne font pas une SCA : il faut deux catégories différentes.

EXEMPTIONS

Les exemptions à la SCA

La SCA systématique serait insupportable pour le client. Les RTS prévoient des exemptions, mais chacune est bornée et surveillée (fraude). La banque doit pouvoir justifier leur usage.

EXEMPTION	PRINCIPE	GARDE-FOU
Faible montant	Paiements de faible valeur sous un plafond	Compteur (nombre / cumul sur une période)
Bénéficiaire de confiance	Paiement vers un bénéficiaire déjà validé	SCA initiale à la création du bénéficiaire
Transaction récurrente	Paiements récurrents d'un même mandat	Premier paiement authentifié
Analyse du risque	Décision de l'ASPSP selon son propre scoring	Plafonds et taux de fraude surveillés
Accès aux soldes AIS	**Consultation après la SCA initiale**	**Jusqu'à 4 consultations/jour, SCA au moins tous les 90 jours**

Exemption ≠ absence de contrôle

Une exemption ne supprime pas la vérification : elle déplace la SCA à un autre moment (création du bénéficiaire, re-authentification périodique) et s'accompagne d'une surveillance de la fraude. Abuser d'une exemption entraîne son retrait.

PREUVE

Non-répudiation et horodatage

Non-répudiation

La banque doit pouvoir **prouver qu'un paiement ou un accès a bien eu lieu** et dans quelles conditions : qui, quel montant, quel bénéficiaire, à quel moment. Un client ne doit pas pouvoir nier un paiement qu'il a autorisé, et le TPP ne doit pas pouvoir contester un appel reçu.

Horodatage

Chaque événement porte une **date et heure de référence** fiable, conservée et cohérente entre les acteurs. C'est la base du contrôle : durée de validité d'un jeton, période de consentement, décompte des exemptions.

Ce que cela impose techniquement

Journalisation horodatée de chaque appel (requête/réponse), signature des messages pour garantir leur intégrité et leur origine (non-répudiation), conservation conforme aux délais légaux. Sans ces preuves, un litige ne peut être tranché.

RISQUES

Trois familles de risques API

Usurpation d'identité

Un attaquant se fait passer pour un TPP agréé ou pour le client.

Contre-mesures : mTLS strict, vérification du registre EBA, contrôle de cohérence certificat/agrément, SCA robuste.

Attaques API

Rejeu de requêtes, injection, déni de service, abus de quota.

Contre-mesures : anti-rejeu (nonce, horodatage), validation des entrées, throttling, quotas par TPP, surveillance d'anomalies.

Fuites de données

Exposition de soldes ou d'opérations au-delà du périmètre consenti, ou interception.

Contre-mesures : scopes minimaux, chiffrement en transit, contrôle de périmètre à chaque appel, pas de données sensibles dans les JWT.

RISQUE	POINT DE CONTRÔLE	MÉCANISME DU JOUR 2
Usurpation	Entrée de la chaîne	mTLS + registre EBA
Attaque API	Gateway & API Management	Throttling, anti-rejeu, validation
Fuite de données	**Services métier**	**Scopes + contrôle de consentement**

SÉQUENCE SUIVANTE

On met tout ensemble

Types d'API, composants, mécanismes d'authentification, exigences et risques : place au cas pratique. Ouvrir une API à un TPP, de bout en bout, avec le schéma, le flux OAuth et les points de contrôle.

COURS — RÉCAPITULATIF DU BLOC

- **SCA** : deux facteurs de catégories différentes (savoir / posséder / être).
- **Exemptions** : faible montant, bénéficiaire de confiance, récurrent, analyse de risque, AIS après SCA initiale — toutes bornées.
- **Non-répudiation + horodatage** : la preuve des opérations.
- **Risques** : usurpation, attaques API, fuites — chacun a son point de contrôle.

07 · S7 · CAS PRATIQUE

S7 · Cas pratique

MISE EN PRATIQUE · TRAVAUX DE GROUPE

Cas pratique

Banque Est doit ouvrir une API à un TPP de bout en bout. À vous de produire le schéma d'architecture, le flux OAuth et les points de contrôle de sécurité.

FIL ROUGE L'application de Lyam (« FinanceApp ») demande à Banque Est un accès en lecture à ses deux comptes. Vous êtes l'équipe technique de Banque Est : il faut le brancher proprement — et en sécurité.

ÉNONCÉ

Le cas

FinanceApp est un AISP agréé. Banque Est doit lui ouvrir un accès en lecture aux comptes d'un client qui l'a autorisé, via une API Open Banking, en respectant les exigences du Jour 2.

ÉLÉMENT	VALEUR
TPP	FinanceApp — agrément AISP
Client	Lyam — 2 comptes (courant + épargne)
Service demandé	Account Information (lecture seule)
Fréquence	Jusqu'à 4 consultations/jour
Durée	**Consentement 90 jours, re-SCA aux 90 jours**

CONSIGNE

Ce qu'il faut produire

01 **Schéma d'architecture** — placer les composants entre FinanceApp et le core bancaire (Gateway, API Management, services AIS, consentement, logs).

02 **Flux d'authentification** — décrire les étapes OAuth2 : demande, redirection, SCA de Lyam, consentement, code, échange contre jeton, appel API.

03 **Points de contrôle sécurité** — pour chaque étape, indiquer le contrôle appliqué (mTLS, vérification registre, scopes, throttling, anti-rejeu) et ce qui est journalisé.

04 **Trois risques et une mesure chacun** — usurpation, attaque API, fuite de données.

Livrable attendu

Une page par groupe : schéma + flux + tableau des points de contrôle + risques/mesures. Restitution 5 min par groupe, synthèse 10 min.

MODÈLE

Points de contrôle — à compléter

ÉTAPE	CONTRÔLE	JOURNALISÉ
1. Demande du TPP	mTLS + vérification registre EBA	identité TPP, horodatage
2. Redirection / SCA	authentification forte de Lyam	résultat SCA, horodatage
3. Consentement	affichage périmètre + validation	périmètre, durée, statut
4. Échange du jeton	code + certificat → access token	émission du jeton, expiration
5. Appels API	Bearer JWT + scopes + consentement + throttling	chaque requête : endpoint, résultat, latence
6. Révocation	**propagation immédiate de la coupure**	**événement de révocation**

ÉVALUATION

Grille

CRITÈRE	POINTS	INDICE D'UN BON TRAVAIL
Schéma complet	4	Tous les composants placés au bon endroit
Flux OAuth	4	Code → jeton → appel, sans étape manquante
Points de contrôle	4	Un contrôle par étape, cohérent
Séparation des identités	3	Client ≠ TPP ≠ autorisation
Risques & mesures	**5**	**Trois risques crédibles, trois mesures**